ID	Control Description	Pass/Fail	Comments
PR.AC-1	Identities and credentials are managed for authorized devices and users.	Fail	While active directory is in use, there aren't enough controls in place to manage authorization effectively.
PR.AC-2	Physical access to assets is managed and protected.	Pass	
PR.AC-3	Remote access is managed.	Fail	VPN is in use, but two factor authentication isn't in place. Contractors remote access isn't managed. Further improvements required.
PR.AC-4	Access permissions are managed, incorporating the principles of least privilege and separation of duties.	Fail	
PR.AC-5	Network integrity is protected, incorporating network segregation where appropriate.	Pass	
PR.AT-1	All users are informed and trained.	Pass	Process could be improved: Employees should undergo security training at least once every 12 months. Consider running simulated phishing attacks to further improve awareness.
PR.AT-2	Privileged users understand roles and responsibilities.	Fail	There is no process to manage privileged user accounts. Admin passwords are shared.
PR.AT-3	Third-party stakeholders (e.g., suppliers, customers, partners) understand roles and responsibilities.	Fail	
PR.AT-4	Senior executives understand roles and responsibilities.	Fail	Board members don't get onboarded to the business like normal employees. Cyber security risk is not managed in this organization so the board members are not aware of their information security responsibilities.
PR.AT-5	Physical and information security personnel understand roles and responsibilities.	Pass	
PR.DS-1	Data-at-rest is protected.	Fail	Data is encrypted by default on Microsoft Office 365. However, data hasn't been identified, classified, or labelled. There is no DLP Capability in place.
PR.DS-2	Data-in-transit is protected.	Fail	
PR.DS-3	Assets are formally managed throughout removal, transfers and disposition.	Fail	
PR.DS-4	Adequate capacity to ensure availability is maintained.	Pass	
PR.DS-5	Protections against data leaks are implemented.	Fail	
PR.DS-6	Integrity checking mechanisms are used to verify software, firmware and information integrity.	Pass	
PR.IP-1	A baseline configuration of information technology/industrial control systems is created and maintained.	Pass	
PR.IP-2	The development and testing environment(s) are separate from the production environment.	N/A	
PR.IP-2	A system development life cycle (SDLC) to manage systems is implemented.	N/A	
PR.IP-3	Configuration change control processes are in place.	Fail	
PR.IP-4	Backups of information are conducted, maintained and tested periodically.	Pass	
PR.IP-5	Policy and regulations regarding the physical operating environment for organizational assets are met.	Pass	
PR.IP-6	Data is destroyed according to policy.	Fail	
PR.IP-7	Protection processes are continuously improved.	Fail	
PR.IP-8	Effectiveness of protection technologies is shared with appropriate parties.	Fail	
PR.IP-9	Response plans (incident response and business continuity) and recovery plans (incident recovery and disaster recovery) are in place and ma	Fail	
PR.IP-10	Response and recovery plans are tested.	Fail	
PR.IP-11	Cybersecurity is included in human resources practices. (e.g., deprovisioning, personnel screening)	Pass	
PR.IP-12	A vulnerability management plan is developed and implemented.	Fail	
PR.MA-1	Maintenance and repair of organizational assets is performed and logged in a timely manner, with approved and controlled tools.	N/A	
PR.MA-2	Remote maintenance of organizational assets is approved, logged and performed in a manner that prevents unauthorized access.	N/A	
PR.PT-1	Audit/log records are determined, documented, implemented and reviewed in accordance with policy.	Fail	Logs don't get reviewed.
PR.PT-2	Removable media is protected and its use restricted according to policy.	Fail	
PR.PT-3	Access to systems and assets is controlled, incorporating the principle of least functionality.	Pass	They use different SaaS solutions for different services.
PR.PT-4	Communications and control networks are protected.	Pass	